

Remediation Plan for Community Nurse Health Center

STATUS:

Open

PERFORMED BY:

Roger Shindell

APPROVED BY:**ASSESSMENT DATE:**

03/23/2015

REMEDIATION PLAN DATE:

04/02/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Location: Corporate							
High	§164.308(a)(2) -Chief Security Officer - Identify the person who is responsible for the development and implementation of the policies and procedure	The organization needs to assign a Chief Security Officer with a job description to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	07/01/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
High	§164.310(b)-Workstation Use - Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed and the physical attributes of the surroundings of a specific workstation or class of workstations that can access ePHI	The organization needs to implement policies and procedures to specify functions to be performed and the physical attributes of surroundings of workstations to secure ePHI to become compliant	PR-135	To-Do	Pamela Hanchar	Angela Curran	07/01/2015
			Questions notes: In process to develop protocol				
Medium	§164.308(a)(1)(ii)(A)-Risk Analysis (required) - Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity and availability of ePHI held by the practice	The organization needs to perform a Risk Analysis and create a Risk Management program to become compliant	AS-210; AS--255; AS-255-FORM-A; AS-255-FORM-B	To-Do	Angela Curran	Angela Curran	07/31/2015
Low	§164.306(d)(1) and §164.306(d)(2)-Implementation Specifications - A covered entity must comply will the standards as provided	The organization needs to learn the HIPAA/HITECH specifications to become compliant	AS-120	To-Do	Angela Curran	Angela Curran	09/29/2015
			Questions notes: Part of annual training program Part of annual training program Part of annual training program				
Low	§164.308(a)(1)(ii)(C)-Sanction Policy (required) - Apply appropriate sanctions against workforce members who fail to comply with security policies and procedures	The organization needs to develop a workforce sanction policy to become compliant	AS-130	To-Do	Phil Foust	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(D)-Information System Activity Review (required) - Implement procedures to regularly review records of information system activity and security incident tracking reports	The organization needs to develop and implement system activity review policies and procedures to track security incidents to become compliant	AS-185; AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(3)(ii)(A)-Authorization and/or Supervision (Addressable) - Implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations	The organization needs to implement policies and procedures to authorize workforce members who access ePHI to become compliant	AS-110; AS-200; AS-200-FORM-A; AS-200-FORM-B	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(B)-Workforce Clearance Procedure (Addressable) - Implement procedures to determine that the access of a workforce member to ePHI is appropriate	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-135	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(C) -Termination Procedure (Addressable) - Implement procedures for terminating access to ePHI when the employment of a workforce member end or the workforce member's clearance changes	The organization needs to implement policies and procedures for terminating access to ePHI when a workforce member's employment terminates to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(A) -Isolating Health Care Clearinghouse Functions (Addressable) - If a clearinghouse is part of the health care organization's function, the clearinghouse must implement policies and procedures that protect the ePHI from unauthorized access	The organization needs to implement policies and procedures for a clearinghouse component of the business to protect ePHI from unauthorized access to become compliant	AS-205	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(B) -Access Authorization (Addressable) - Implement policies and procedures for granting access to ePHI through access to a workstation, transaction, program, process or other program	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-110	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	\$164.308(a)(5)(ii)(A) -Security Reminders (Addressable) - Periodic security updates	The organization needs to implement a procedure to remind the workforce of security updates to become compliant	AS-135	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	\$164.308(a)(5)(ii)(B)-Protection from Malicious Software (Addressable) - Procedures for guarding against, detecting and reporting malicious software	The organization needs to implement policies and procedures for guarding against malicious software entering the practice's computer systems to become compliant	AS-215	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	\$164.308(a)(5)(ii)(C)-Log-in Monitoring (Addressable) - Procedures for monitoring log-in attempts and reporting discrepancies	The organization needs to implement policies and procedures for monitoring log-in attempts to become compliant	AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Questions notes: Log in attempts are tracked, alerts are generated if a server is attempted to be accessed by an unknown urls, IP addresses							
Low	\$164.308(a)(5)(ii)(D) -Password Management (Addressable) - Procedures for creating, changing and safeguarding passwords	The organization needs to implement policies and procedures for creating, changing and safeguarding passwords to become compliant	PR-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(6)(ii) -Security Incidents - Response and Reporting - Implement policies and procedures to identify and respond to suspected or known security incidents, mitigate to the extent practicable, harmful effects of security incidents known by the covered entity; and document security incidents	The organization needs to policies and procedures to identify and respond to suspected or known security incidents and to mitigate the harmful effects of security incidents to become compliant	AS-170; AS-175; AS-180	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(A) -Data Backup Plan (Required) - Establish and implement procedures to create and maintain retrievable exact copies of ePHI	The organization needs to implement policies and procedures to backup ePHI and maintain retrieveable exact copies of ePHI to become compliant	AS-225	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: Everything is cloud based				
Low	§164.308(a)(7)(ii)(B) -Disaster Recovery Plan (Required) - Establish (and implement as needed) procedures to restore any lost data	The organization needs to implement policies and procedures to restore any lost data in the event of recovering from a disaster to become compliant	AS-230	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: Backups are tested to make sure they can be restored				
Low	§164.308(a)(7)(ii)(C) -Emergency Mode Operation Plan (Required) - Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of ePHI while operating in an emergency mode	The organization needs to implement policies and procedures to enable critical business procedures for protecting the security of ePHI while working in an emergency mode to become compliant	AS-235	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: EHR, (ECW) is cloud based Need to develop				

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(7)(ii)(D) -Testing and Revision Procedures (Required) - Implement procedures for the periodic testing and revision of contingency plans	The organization needs to implement policies and procedures for periodic testing and revision of contingency plans to become compliant	AS-240	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(E)-Applications and Data Criticality Analysis (Required) - Assess the relative criticality of specific applications and data in support of other contingency plan components	The organization needs to assess the criticality of specific applications in support of contingency plan components to become compliant	AS-250	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(8)(4) -Written contract or other arrangement (Required) - Document the satisfactory assurances required by this regulation that the business associate meets the applicable requirements	The organization needs to confirm that the practice's business associate agreements require satisfactory assurances from the business associate that they meet HIPAA/HITECH requirements to become compliant	AS-260	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.310(a)(2)(i) -Contingency Operations (Required) - Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency	The organization needs to policies and procedures for allowing access in support of restoration of lost data under the disaster plan in the event of an emergency to become compliant	PS-155	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

[illegible]

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(d)(2)(i)-Disposal (Required) - Implement policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored	The organization needs to implement policies and procedures to address the final disposition of ePHI and the hardware or electronic media on which the ePHI is stored to become compliant	PS-115; PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: Disposal is complete destruction of hard drives				
Low	§164.310(d)(2)(ii)-Media Use (Required) - Implement policies and procedures for removal of ePHI from electronic media before the media is made available for re-use	The organization needs to implement policies and procedures for removal of ePHI from electronic media before media is made for re-use to become compliant	PR-135-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: No media is resused				
Low	§164.310(d)(2)(iii)-Accountability (Required) - Maintain a record of the movements of hardware and electronic media and any person responsible for the movement	The organization needs to develop and maintain a record of movements of electronic media to become compliant	PR-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: System is scanned for assets				
Low	§164.310(d)(2)(iv)-Data Backup and Storage (Required) - Create and retrievable copy of ePHI, when needed, before movement of equipment	The organization needs to implement procedures to ensure that a regular retrieveable copy of ePHI is made before equipment containing ePHI is moved to become compliant	PR-145-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
			Questions notes: All data resides on Eclinicalworks servers				

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(a)(2)(i)-Unique User Identification (Required) - Assign a unique name and/or number for identifying and tracking user identity	The organization needs to ensure that each user has a unique name for tracking user identity to become compliant	PR-135-Form-b	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(a)(2)(ii)-Emergency Access Procedure (Required) - Establish (and implement as needed) procedures for obtaining necessary ePHI during an emergency	The organization needs to develop and implement procedures for obtaining ePHI during an emergency to become compliant	PR-150	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(a)(2)(iii)-Automatic Logoff(Addressable) - Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity	The organization needs to implement electronic procedures to terminate a workstation activity after a pre-determined time of activity to become compliant	PR-135-Form-c	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(a)(2)(iv)-Encryption and Decryption (Addressable) - Implement a mechanism to encrypt and decrypt ePHI	The organization needs implement a mechanism to encrypt and decrypt ePHI to become compliant	PR-120	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Questions notes: EClinicalWorks encrypts all data residing on their servers							
Low	§164.312(b) -Audit Controls - Implement hardware, software and/or procedural mechanisms that record and examine activity in information systems that contain ePHI	The organization needs to implement hardware, software and procedural mechanisms to record and examine activity in accessing and using ePHI to become compliant	AS-145	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(c)(1) -Integrity - Implement policies and procedures to protect ePHI from improper alteration or destruction	The organization needs to implement policies and procedures to protect ePHI from improper alteration or destruction to become compliant	PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(c)(2)-Mechanism to Authenticate ePHI - Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner	The organization needs to implement electronic mechanisms to corroborate that ePHI has not altered or destroyed in an authorized manner to become compliant	PR-155	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(d) -Person or entity authentication - Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed	The organization needs to implement procedures to verify the person seeking to access ePHI is the one claimed to become compliant	TS-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(e)(2)(i)-Integrity Controls (Addressable) - Implement security measures to ensure that electronically transmitted ePHI is not properly modified without detection until disposed of	The organization needs to implement security measures to ensure that electronically transmitted ePHI is no modified with detection until properly disposed of to become compliant	PR-120-Form	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(e)(2)(ii) -Encryption (Addressable) - Implement a mechanism to encrypt ePHI whenever being transmitted	The organization needs to implement a mechanism to encrypt ePHI whenever it is transmitted to become compliant	TS-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.314(a)(1)(ii)-Business Associate contracts - A covered entity is not in compliance if the covered entity knows of a pattern of an activity or practice of the business associate that constituted a material breach of the business associate's obligations unless the covered entity took reasonable steps to cure the breach	The organization needs to ensure that it has reasonable procedures in place with its business associates to ensure that the business notify the organization if the business associate commits a breach to become compliant	AS-260	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.314(a)(2)(i)A), (B), (C), (D) -Business Associate contracts - Implementation - Business Associate Agreements must provide that the Business Associate will include the following requirements	The organization needs to ensure that the business associate agreement has all of the necessary requirements to become compliant	AS-260; AS-265; PR-270	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (a) -Policies and Procedures and Documentation Requirements - Implement reasonable and appropriate policies to comply with the standards, implementation specifications or other requirements of the regulation	The organization needs to implement procedures to be sure comply with all of the regulation's requirements to become compliant	AS-125; DR-105	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(i)-Time Limit (Required) - Retain the required documentation for 6 years from the date of the creation	The organization needs to be sure that all documentation is retained for 6 years from the date of creation to become compliant	AS-155	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(ii) -Availability (Required) - Make documentation available to those responsible for implementing the procedures to which the documentation pertains	The organization needs to make documentation available to those responsible for implementing the procedures to become compliant	PR-160	To-Do	Angela Curran	Angela Curran	09/29/2015

Questions notes:

All Policies and Procedures are on the shared ("Z") drive

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.316 (b)(2)(iii) -Updates (Required) - Periodically review documentation and update as needed in response to environmental or operational changes affecting security of the ePHI	The organization needs to periodically review documentation and update the documentation as needed in response to environmental or operational changes to become compliant	PR-140	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(i)-Asset Inventory (Required) -	Implement policies and procedures to prevent, detect, contain and correct security violations		To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(1)-Physical Access for Authorized Sever Access -	Implement policies and procedures tp limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properlu authorized access is allowed		To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Location: Dental Center							
Low	§164.306(d)(1) and §164.306(d)(2)- Implementation Specifications - A covered entity must comply will the standards as provided	The organization needs to learn the HIPAA/HITECH specifications to become compliant	AS-120	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(A)-Risk Analysis (required) - Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity and availability of ePHI held by the practice	The organization needs perform a Risk Analysis and create a Risk Management program to become compliant	AS-210; AS--255; AS-255-FORM-A; AS-255-FORM-B	To-Do	Angela Curran	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(1)(ii)(C)-Sanction Policy (required) - Apply appropriate sanctions against workforce members who fail to comply with security policies and procedures	The organization needs to develop a workforce sanction policy to become compliant	AS-130	To-Do	Phil Foust	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(D)-Information System Activity Review (required) - Implement procedures to regularly review records of information system activity and security incident tracking reports	The organization needs to develop and implement system activity review policies and procedures to track security incidents to become compliant	AS-185; AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(2) -Chief Security Officer - Identify the person who is responsible for the development and implementation of the policies and procedure	The organization needs to assign a Chief Security Officer with a job description to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(A)-Authorization and/or Supervision (Addressable) - Implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations	The organization needs to implement policies and procedures to authorize workforce members who access ePHI to become compliant	AS-110; AS-200; AS-200-FORM-A; AS-200-FORM-B	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(B)-Workforce Clearance Procedure (Addressable) - Implement procedures to determine that the access of a workforce member to ePHI is appropriate	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-135	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(3)(ii)(C) -Termination Procedure (Addressable) - Implement procedures for terminating access to ePHI when the employment of a workforce member end or the workforce member's clearance changes	The organization needs to implement policies and procedures for terminating access to ePHI when a workforce member's employment terminates to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(A) -Isolating Health Care Clearinghouse Functions (Addressable) - If a clearinghouse is part of the health care organization's function, the clearinghouse must implement policies and procedures that protect the ePHI from unauthorized access	The organization needs to implement policies and procedures for a clearinghouse component of the business to protect ePHI from unauthorized access to become compliant	AS-205	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(B) -Access Authorization (Addressable) - Implement policies and procedures for granting access to ePHI through access to a workstation, transaction, program, process or other program	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-110	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(A) -Security Reminders (Addressable) - Periodic security updates	The organization needs implement a procedure to remind the workforce of security updates to become compliant	AS-135	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(B)-Protection from Malicious Software (Addressable) - Procedures for guarding against, detecting and reporting malicious software	The organization needs to implement policies and procedures for guarding against malcious software entering the practice's computer systems to become compliant	AS-215	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(5)(ii)(C)-Log-in Monitoring (Addressable) - Procedures for monitoring log-in attempts and reporting discrepancies	The organization needs to implement policies and procedures for monitoring log-in attempts to become compliant	AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(D) -Password Management (Addressable) - Procedures for creating, changing and safeguarding passwords	The organization needs to implement policies and procedures for creating, changing and safeguarding passwords to become compliant	PR-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(6)(ii) -Security Incidents - Response and Reporting - Implement policies and procedures to identify and respond to suspected or known security incidents, mitigate to the extent practicable, harmful effects of security incidents known by the covered entity; and document security incidents	The organization needs to policies and procedures to identify and respond to suspected or known security incidents and to mitigate the harmful effects of security incidents to become compliant	AS-170; AS-175; AS-180	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(A) -Data Backup Plan (Required) - Establish and implement procedures to create and maintain retrievable exact copies of ePHI	The organization needs to implement policies and procedures to backup ePHI and maintain retrieveable exact copies of ePHI to become compliant	AS-225	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(B) -Disaster Recovery Plan (Required) - Establish (and implement as needed) procedures to restore any lost data	The organization needs to implement policies and procedures to restore any lost data in the event of recovering from a disaster to become compliant	AS-230	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(7)(ii)(C) -Emergency Mode Operation Plan (Required) - Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of ePHI while operating in an emergency mode	The organization needs to implement policies and procedures to enable critical business procedures for protecting the security of ePHI while working in an emergency mode to become compliant	AS-235	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(D) -Testing and Revision Procedures (Required) - Implement procedures for the periodic testing and revision of contingency plans	The organization needs to implement policies and procedures for periodic testing and revision of contingency plans to become compliant	AS-240	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(E)-Applications and Data Criticality Analysis (Required) - Assess the relative criticality of specific applications and data in support of other contingency plan components	The organization needs to assess the criticality of specific applications in support of contingency plan components to become compliant	AS-250	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(8)(4) -Written contract or other arrangement (Required) - Document the satisfactory assurances required by this regulation that the business associate meets the applicable requirements	The organization needs to confirm that the practice's business associate agreements require satisfactory assurances from the business associate that they meet HIPAA/HITECH requirements to become compliant	AS-260	To-Do	Angela Curran	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(a)(2)(i) -Contingency Operations (Required) - Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency	The organization needs to policies and procedures for allowing access in support of restoration of lost data under the disaster plan in the event of an emergency to become compliant	PS-155	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(2)(ii) -Facility Security Plan (Required) - Implement policies and procedures to safeguard the facility and the equipment from unauthorized access, tampering and theft	The organization needs to implement policies and procedures to safeguard the facility from unauthorized access tampering and theft of equipment to become compliant	PS-130; PS-120	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(2)(iii) -Access Control and Validation Procedures (Required) - Implement policies and procedures to control and validate a person's access to facilities based on their role or function and control access to software programs for testing and revisions	The organization needs to implement policies and procedures to control and validate a person's access to facilities based on their role or function to become compliant	PR-130-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.310(a)(2)(iv)-Maintenance Records (Required) - Implement policies and procedures to document repairs and modifications to the physical components of the facility which are related to security	The organization needs to implement policies and procedures to document repairs and modifications to the physical components of the facility to become compliant	AS-195-Form-b	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(b)-Workstation Use - Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed and the physical attributes of the surroundings of a specific workstation or class of workstations that can access ePHI	The organization needs to implement policies and procedures to specify functions to be performed and the physical attributes of surroundings of workstations to secure ePHI to become compliant	PR-135	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(c)-Workstation Security - Implement physical safeguards for all workstations, and other devices, that access ePHI to restrict access to authorized users	The organization needs to implement physical safeguards for all workstations and other devices to restrict access to only authorized users to ePHI to become compliant	PR-130-Form-c	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(d)(2)(i)-Disposal (Required) - Implement policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored	The organization needs to implement policies and procedures to address the final disposition of ePHI and the hardware or electronic media on which the ePHI is stored to become compliant	PS-115; PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.310(d)(2)(ii)-Media Use (Required) - Implement policies and procedures for removal of ePHI from electronic media before the media is made available for re-use	The organization needs to implement policies and procedures for removal of ePHI from electronic media before media is made for re-use to become compliant	PR-135-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(d)(2)(iii)-Accountability (Required) - Maintain a record of the movements of hardware and electronic media and any person responsible for the movement	The organization needs to develop and maintain a record of movements of electronic media to become compliant	PR-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.310(d)(2)(iv)-Data Backup and Storage (Required) - Create and retrievable copy of ePHI, when needed, before movement of equipment	The organization needs to implement procedures to ensure that a regular retrieveable copy of ePHI is made before equipment containing ePHI is moved to become compliant	PR-145-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(a)(2)(i)-Unique User Identification (Required) - Assign a unique name and/or number for identifying and tracking user identity	The organization needs to ensure that each user has a unique name for tracking user identity to become compliant	PR-135-Form-b	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(a)(2)(ii)-Emergency Access Procedure (Required) - Establish (and implement as needed) procedures for obtaining necessary ePHI during an emergency	The organization needs to develop and implement procedures for obtaining ePHI during an emergency to become compliant	PR-150	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(a)(2)(iii)-Automatic Logoff(Addressable) - Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity	The organization needs to implement electronic procedures to terminate a workstation activity after a pre-determined time of activity to become compliant	PR-135-Form-c	To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(a)(2)(iv)-Encryption and Decryption (Addressable) - Implement a mechanism to encrypt and decrypt ePHI	The organization needs to implement a mechanism to encrypt and decrypt ePHI to become compliant	PR-120	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(b) -Audit Controls - Implement hardware, software and/or procedural mechanisms that record and examine activity in information systems that contain ePHI	The organization needs to implement hardware, software and procedural mechanisms to record and examine activity in accessing and using ePHI to become compliant	AS-145	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(c)(1) -Integrity - Implement policies and procedures to protect ePHI from improper alteration or destruction	The organization needs to implement policies and procedures to protect ePHI from improper alteration or destruction to become compliant	PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(c)(2)-Mechanism to Authenticate ePHI - Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner	The organization needs to implement electronic mechanisms to corroborate that ePHI has not altered or destroyed in an authorized manner to become compliant	PR-155	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(d) -Person or entity authentication - Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed	The organization needs to implement procedures to verify the person seeking to access ePHI is the one claimed to become compliant	TS-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(e)(2)(i)-Integrity Controls (Addressable) - Implement security measures to ensure that electronically transmitted ePHI is not properly modified without detection until disposed of	The organization needs to implement security measures to ensure that electronically transmitted ePHI is no modified with detection until properly disposed of to become compliant	PR-120-Form	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(e)(2)(ii) -Encryption (Addressable) - Implement a mechanism to encrypt ePHI whenever being transmitted	The organization needs to implement a mechanism to encrypt ePHI whenever it is transmitted to become compliant	TS-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.314(a)(1)(ii)-Business Associate contracts - A covered entity is not in compliance if the covered entity knows of a pattern of an activity or practice of the business associate that constituted a material breach of the business associate's obligations unless the covered entity took reasonable steps to cure the breach	The organization needs to ensure that it has reasonable procedures in place with its business associates to ensure that the business notify the organization if the business associate commits a breach to become compliant	AS-260	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.314(a)(2)(i)A), (B), (C), (D) -Business Associate contracts - Implementation - Business Associate Agreements must provide that the Business Associate will include the following requirements	The organization needs to ensure that the business associate agreement has all of the necessary requirements to become compliant	AS-260; AS-265; PR-270	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (a) -Policies and Procedures and Documentation Requirements - Implement reasonable and appropriate policies to comply with the standards, implementation specifications or other requirements of the regulation	The organization needs to implement procedures to be sure comply with all of the regulation's requirements to become compliant	AS-125; DR-105	To-Do	Angela Curran	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.316 (b)(2)(i)-Time Limit (Required) - Retain the required documentation for 6 years from the date of the creation	The organization needs to be sure that all documentation is retained for 6 years from the date of creation to become compliant	AS-155	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(ii) -Availability (Required) - Make documentation available to those responsible for implementing the procedures to which the documentation pertains	The organization needs to make documentation available to those responsible for implementing the procedures to become compliant	PR-160	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(iii) -Updates (Required) - Periodically review documentation and update as needed in response to environmental or operational changes affecting security of the ePHI	The organization needs to periodically review documentation and update the documentation as needed in response to environmental or operational changes to become compliant	PR-140	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(i)-Asset Inventory (Required) -	Implement policies and procedures to prevent, detect, contain and correct security violations		To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(1)-Physical Access for Authorized Sever Access -	Implement policies and procedures tp limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properlu authorized access is allowed		To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Location: Medical Center							
Low	§164.306(d)(1) and §164.306(d)(2)- Implementation Specifications - A covered entity must comply will the standards as provided	The organization needs to learn the HIPAA/HITECH specifications to become compliant	AS-120	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(A)-Risk Analysis (required) - Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity and availability of ePHI held by the practice	The organization needs perform a Risk Analysis and create a Risk Management program to become compliant	AS-210; AS--255; AS-255-FORM-A; AS-255-FORM-B	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(C)-Sanction Policy (required) - Apply appropriate sanctions against workforce members who fail to comply with security policies and procedures	The organization needs to develop a workforce sanction policy to become compliant	AS-130	To-Do	Phil Foust	Angela Curran	09/29/2015
Low	§164.308(a)(1)(ii)(D)-Information System Activity Review (required) - Implement procedures to regularly review records of information system activity and security incident tracking reports	The organization needs to develop and implement system activity review policies and procedures to track security incidents to become compliant	AS-185; AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(2) -Chief Security Officer - Identify the person who is responsible for the development and implementation of the policies and procedure	The organization needs to assign a Chief Security Officer with a job description to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(3)(ii)(A)-Authorization and/or Supervision (Addressable) - Implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations	The organization needs to implement policies and procedures to authorize workforce members who access ePHI to become compliant	AS-110; AS-200; AS-200-FORM-A; AS-200-FORM-B	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(B)-Workforce Clearance Procedure (Addressable) - Implement procedures to determine that the access of a workforce member to ePHI is appropriate	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-135	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(3)(ii)(C) -Termination Procedure (Addressable) - Implement procedures for terminating access to ePHI when the employment of a workforce member end or the workforce member's clearance changes	The organization needs to implement policies and procedures for terminating access to ePHI when a workforce member's employment terminates to become compliant	AS-140	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(A) -Isolating Health Care Clearinghouse Functions (Addressable) - If a clearinghouse is part of the health care organization's function, the clearinghouse must implement policies and procedures that protect the ePHI from unauthorized access	The organization needs to implement policies and procedures for a clearinghouse component of the business to protect ePHI from unauthorized access to become compliant	AS-205	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(4)(ii)(B) -Access Authorization (Addressable) - Implement policies and procedures for granting access to ePHI through access to a workstation, transaction, program, process or other program	The organization needs to implement policies and procedures for granting ePHI to the workforce to become compliant	AS-110	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(5)(ii)(A) -Security Reminders (Addressable) - Periodic security updates	The organization needs to implement a procedure to remind the workforce of security updates to become compliant	AS-135	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(B)-Protection from Malicious Software (Addressable) - Procedures for guarding against, detecting and reporting malicious software	The organization needs to implement policies and procedures for guarding against malicious software entering the practice's computer systems to become compliant	AS-215	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(C)-Log-in Monitoring (Addressable) - Procedures for monitoring log-in attempts and reporting discrepancies	The organization needs to implement policies and procedures for monitoring log-in attempts to become compliant	AS-220	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(5)(ii)(D) -Password Management (Addressable) - Procedures for creating, changing and safeguarding passwords	The organization needs to implement policies and procedures for creating, changing and safeguarding passwords to become compliant	PR-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.308(a)(6)(ii) -Security Incidents - Response and Reporting - Implement policies and procedures to identify and respond to suspected or known security incidents, mitigate to the extent practicable, harmful effects of security incidents known by the covered entity; and document security incidents	The organization needs to policies and procedures to identify and respond to suspected or known security incidents and to mitigate the harmful effects of security incidents to become compliant	AS-170; AS-175; AS-180	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(7)(ii)(A) -Data Backup Plan (Required) - Establish and implement procedures to create and maintain retrievable exact copies of ePHI	The organization needs to implement policies and procedures to backup ePHI and maintain retrievable exact copies of ePHI to become compliant	AS-225	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(B) -Disaster Recovery Plan (Required) - Establish (and implement as needed) procedures to restore any lost data	The organization needs to implement policies and procedures to restore any lost data in the event of recovering from a disaster to become compliant	AS-230	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(C) -Emergency Mode Operation Plan (Required) - Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of ePHI while operating in an emergency mode	The organization needs to implement policies and procedures to enable critical business procedures for protecting the security of ePHI while working in an emergency mode to become compliant	AS-235	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(D) -Testing and Revision Procedures (Required) - Implement procedures for the periodic testing and revision of contingency plans	The organization needs to implement policies and procedures for periodic testing and revision of contingency plans to become compliant	AS-240	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.308(a)(7)(ii)(E)-Applications and Data Criticality Analysis (Required) - Assess the relative criticality of specific applications and data in support of other contingency plan components	The organization needs to assess the criticality of specific applications in support of contingency plan components to become compliant	AS-250	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.308(a)(8)(4) -Written contract or other arrangement (Required) - Document the satisfactory assurances required by this regulation that the business associate meets the applicable requirements	The organization needs to confirm that the practice's business associate agreements require satisfactory assurances from AS-260 the business associate that they meet HIPAA/HITECH requirements to become compliant		To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.310(a)(2)(i) -Contingency Operations (Required) - Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency	The organization needs to policies and procedures for allowing access in support of restoration of lost data under the disaster plan in the event of an emergency to become compliant	PS-155	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(2)(ii) -Facility Security Plan (Required) - Implement policies and procedures to safeguard the facility and the equipment from unauthorized access, tampering and theft	The organization needs to implement policies and procedures to safeguard the facility from unauthorized access tampering and theft of equipment to become compliant	PS-130; PS-120	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(a)(2)(iii) -Access Control and Validation Procedures (Required) - Implement policies and procedures to control and validate a person's access to facilities based on their role or function and control access to software programs for testing and revisions	The organization needs to implement policies and procedures to control and validate a person's access to facilities based on their role or function to become compliant	PR-130-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(a)(2)(iv)-Maintenance Records (Required) - Implement policies and procedures to document repairs and modifications to the physical components of the facility which are related to security	The organization needs to implement policies and procedures to document repairs and modifications to the physical components of the facility to become compliant	AS-195-Form-b	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(b)-Workstation Use - Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed and the physical attributes of the surroundings of a specific workstation or class of workstations that can access ePHI	The organization needs to implement policies and procedures to specify functions to be performed and the physical attributes of surroundings of workstations to secure ePHI to become compliant	PR-135	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(c)-Workstation Security - Implement physical safeguards for all workstations, and other devices, that access ePHI to restrict access to authorized users	The organization needs to implement physical safeguards for all workstations and other devices to restrict access to only authorized users to ePHI to become compliant	PR-130-Form-c	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.310(d)(2)(i)-Disposal (Required) - Implement policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored	The organization needs to implement policies and procedures to address the final disposition of ePHI and the hardware or electronic media on which the ePHI is stored to become compliant	PS-115; PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(d)(2)(ii)-Media Use (Required) - Implement policies and procedures for removal of ePHI from electronic media before the media is made available for re-use	The organization needs to implement policies and procedures for removal of ePHI from electronic media before media is made for re-use to become compliant	PR-135-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.310(d)(2)(iii)-Accountability (Required) - Maintain a record of the movements of hardware and electronic media and any person responsible for the movement	The organization needs to develop and maintain a record of movements of electronic media to become compliant	PR-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.310(d)(2)(iv)-Data Backup and Storage (Required) - Create and retrievable copy of ePHI, when needed, before movement of equipment	The organization needs to implement procedures to ensure that a regular retrieveable copy of ePHI is made before equipment containing ePHI is moved to become compliant	PR-145-Form-a	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(a)(2)(i)-Unique User Identification (Required) - Assign a unique name and/or number for identifying and tracking user identity	The organization needs to ensure that each user has a unique name for tracking user identity to become compliant	PR-135-Form-b	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(a)(2)(ii)-Emergency Access Procedure (Required) - Establish (and implement as needed) procedures for obtaining necessary ePHI during an emergency	The organization needs to develop and implement procedures for obtaining ePHI during an emergency to become compliant	PR-150	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(a)(2)(iii)-Automatic Logoff(Addressable) - Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity	The organization needs to implement electronic procedures to terminate a workstation activity after a pre-determined time of activity to become compliant	PR-135-Form-c	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(a)(2)(iv)-Encryption and Decryption (Addressable) - Implement a mechanism to encrypt and decrypt ePHI	The organization needs implement a mechanism to encrypt and decrypt ePHI to become compliant	PR-120	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(b) -Audit Controls - Implement hardware, software and/or procedural mechanisms that record and examine activity in information systems that contain ePHI	The organization needs to implement hardware, software and procedural mechanisms to record and examine activity in accessing and using ePHI to become compliant	AS-145	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(c)(1) -Integrity - Implement policies and procedures to protect ePHI from improper alteration or destruction	The organization needs to implement policies and procedures to protect ePHI from improper alteration or distruction to become compliant	PS-105	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(c)(2)-Mechanism to Authenticate ePHI - Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner	The organization needs to implement electronic mechanisms to corroborate that ePHI has not altered or destroyed in an authorized manner to become compliant	PR-155	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.312(d) -Person or entity authentication - Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed	The organization needs to implement procedures to verify the person seeking to access ePHI is the one claimed to become compliant	TS-145	To-Do	Antonia Rodriguez	Angela Curran	09/29/2015
Low	§164.312(e)(2)(i)-Integrity Controls (Addressable) - Implement security measures to ensure that electronically transmitted ePHI is not properly modified without detection until disposed of	The organization needs to implement security measures to ensure that electronically transmitted ePHI is no modified with detection until properly disposed of to become compliant	PR-120-Form	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.312(e)(2)(ii) -Encryption (Addressable) - Implement a mechanism to encrypt ePHI whenever being transmitted	The organization needs to implement a mechanism to encrypt ePHI whenever it is transmitted to become compliant	TS-115	To-Do	Pamela Hanchar	Angela Curran	09/29/2015
Low	§164.314(a)(1)(ii)-Business Associate contracts - A covered entity is not in compliance if the covered entity knows of a pattern of an activity or practice of the business associate that constituted a material breach of the business associate's obligations unless the covered entity took reasonable steps to cure the breach	The organization needs to ensure that it has reasonable procedures in place with its business associates to ensure that the business notify the organization if the business associate commits a breach to become compliant	AS-260	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.314(a)(2)(i)A), (B), (C), (D) -Business Associate contracts - Implementation - Business Associate Agreements must provide that the Business Associate will include the following requirements	The organization needs to ensure that the business associate agreement has all of the necessary requirements to become compliant	AS-260; AS-265; PR-270	To-Do	Angela Curran	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.316 (a) -Policies and Procedures and Documentation Requirements - Implement reasonable and appropriate policies to comply with the standards, implementation specifications or other requirements of the regulation	The organization needs to implement procedures to be sure comply with all of the regulation's requirements to become compliant	AS-125; DR-105	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(i)-Time Limit (Required) - Retain the required documentation for 6 years from the date of the creation	The organization needs to be sure that all documentation is retained for 6 years from the date of creation to become compliant	AS-155	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(ii) -Availability (Required) - Make documentation available to those responsible for implementing the procedures to which the documentation pertains	The organization needs to make documentation available to those responsible for implementing the procedures to become compliant	PR-160	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.316 (b)(2)(iii) -Updates (Required) - Periodically review documentation and update as needed in response to environmental or operational changes affecting security of the ePHI	The organization needs to periodically review documentation and update the documentation as needed in response to environmental or operational changes to become compliant	PR-140	To-Do	Angela Curran	Angela Curran	09/29/2015
Low	§164.308(a)(1)(i)-Asset Inventory (Required) -	Implement policies and procedures to prevent, detect, contain and correct security violations		To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Risk score	Threat	Action plan	Policy number	Status	Assignee	Approver	Target Date
Low	§164.310(a)(1)-Physical Access for Authorized Sever Access -	Implement policies and procedures tp limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properlu authorized access is allowed		To-Do	Pamela Hanchar	Angela Curran	09/29/2015

Reviewed and approved by

Initials:

Date:

Agreed to and accepted by

Initials:

Date: